



Sicurezza del Software

Università degli Studi di Verona

Imbriani Paolo, VR553697

paolo.imbriani@studenti.univr.it

Professor Mila della Preda

INDICE

1	Vulnerabilità del Software	3
1.1	SQL Injection	3
1.1.1	Come difendersi	3
1.2	Buffer Overflow	3
1.2.1	Come difendersi	3
1.3	Authentication Failure	4
1.3.1	Come difendersi	4
1.4	Software Tampering / Supply Chain Attack	4
1.4.1	Come difendersi	5
2	Cosa è la Computer Security?	5
2.1	Origini	5
3	Software Security	7
3.1	Minaccia	7
3.1.1	Valutazione del rischio	9

1 VULNERABILITÀ DEL SOFTWARE

1.1 SQL INJECTION

Uno degli attacchi più famosi e pericolosi è l'SQL Injection. Questo tipo di attacco sfrutta le vulnerabilità nelle applicazioni web che interagiscono con un database SQL.

1. L'attaccante inserisce una query SQL malevola in un campo di input dell'applicazione, come un modulo di login o una barra di ricerca.
2. Se l'applicazione non valida correttamente l'input, la query malevola viene eseguita sul database, permettendo all'attaccante di accedere a dati sensibili, modificare o cancellare informazioni.
3. L'attaccante ripete 1 e 2 finché non ottiene le informazioni desiderate.

1.1.1 COME DIFENDERSI

I modi per difendersi dall'SQL Injection sono i seguenti:

- Parametrized queries
- Input Validation
- Least Privilege
- Limit error explanation, l'overexplanation degli errori può semplificare la vita all'attaccante
- SW Testing

1.2 BUFFER OVERFLOW

Il Buffer Overflow è un'altra vulnerabilità comune che si verifica quando un programma scrive più dati in un buffer di quanto esso possa contenere. Nel momento in cui viene fatto ciò, la memoria del programma viene corrotta (Memory Corruption), portando a:

- Crash / Denial of Service (DOS)
- Remote Code Execution (RCE)
- Bypass Control
- Log deletion
- Information Disclosure
- Shellcode injection
- Control flow hijacking

Il principale obiettivo è compromettere la memoria e il control flow di un programma eseguito e di conseguenza dare potenzialmente problemi all'intero sistema.

1.2.1 COME DIFENDERSI

I modi per difendersi da questo attacco sono i seguenti:

- Secure Functions
- Memory safe languages
- Compiler and OS protections
- SW Testing
- Check memory limits

1.3 AUTHENTICATION FAILURE

Ci sono diversi tipi di vulnerabilità legate all'autenticazione, tra cui:

- Weak passwords: password deboli o facilmente indovinabili.
- MFA bypass: vulnerabilità che permettono di bypassare l'autenticazione a più fattori.
- Credential stuffing: attacco che sfrutta credenziali rubate da altri servizi per accedere a un account. Questo è il motivo per cui è sconsigliato usare la stessa password per molti servizi e soprattutto usarla per un servizio importante come la banca, università, etc...
- Incorrect Session Management: vulnerabilità nella gestione delle sessioni che possono permettere a un attaccante di impersonare un utente legittimo.
- SQL Injection: vulnerabilità che permette a un attaccante di eseguire query SQL malevole per ottenere accesso non autorizzato.

L'attaccante è capace di entrare all'interno del sistema con le credenziali di una vittima. Vengono rubate le credenziali di un utente legittimo e l'attaccante può accedere al sistema come se fosse quell'utente oppure accedere ai servizi della vittima o «chiudere» la vittima fuori dal proprio account.

1.3.1 COME DIFENDERSI

I modi per difendersi da questo attacco sono i seguenti:

- Secure Password
- Anomaly Detection
- MFA
- Unique Password
- Rate limiting

1.4 SOFTWARE TAMPERING / SUPPLY CHAIN ATTACK

In questo attacco, il codice di un software viene modificato in modo malevolo, spesso durante il processo di sviluppo o distribuzione. L'attaccante può inserire codice dannoso che può compromettere la sicurezza del software e dei dati degli utenti. Spesso, nelle Supply Chain Attack, vengono attaccate librerie all'interno di package manager in modo da compromettere gli utenti che le utilizzano e quindi attacca tutta la supply chain.

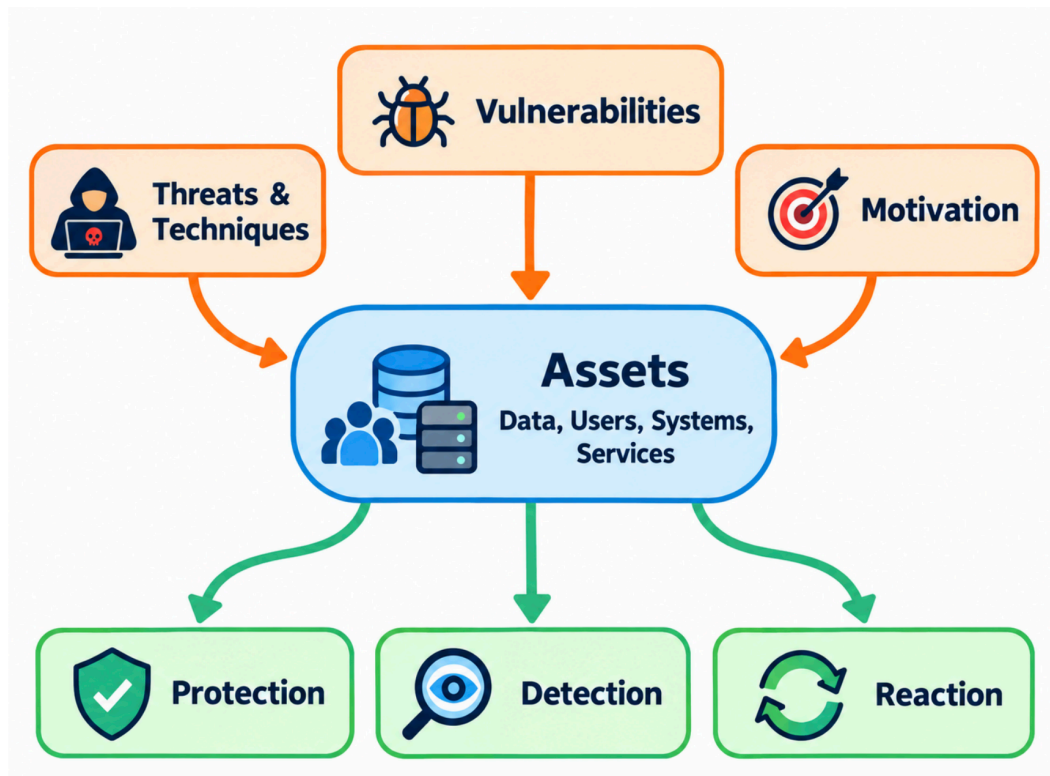
1.4.1 COME DIFENDERSI

I modi per difendersi da questo attacco sono i seguenti:

- Monitoring application behaviour
- Code obfuscation
- Integrity check
- Review updates
- Use SBOMs (Software Bill of Materials) and dependencies scanning
- Have an incident-response plan

2 COSA È LA COMPUTER SECURITY?

La sicurezza del software è la disciplina che si occupa di implementare, distribuire e mantenere software che si comporta nella maniera intesa e resiste ad accessi, usi, modifiche non autorizzate.



- L'attaccante vuole ottenere gli asset del sistema (data, utenti, sistemi, servizi)
- Il difensore può proteggersi, riconoscere gli attacchi o reagire in caso di attacco non previsto.

2.1 ORIGINI

La sicurezza informatica nasce negli anni “70, quando i computer erano grandi e costosi e le persone che li utilizzavano erano poche. In quel periodo, la sicurezza era principalmente fisica, con accesso limitato ai computer e alle sale server. Già nel “72, un report chiamato «Computer Security Technology Planning Study» identifica una serie di punti critici sui sistemi

che si stavano adottando, come la continua evoluzione dei sistemi tecnologici, la mancanza di standardizzazione e la necessità di proteggere le informazioni sensibili. Nel '76, un altro report, chiamato «Operating Systems Structures to Support Security and Reliable Software», identifica una serie di vulnerabilità legate ai sistemi operativi e propone soluzioni per migliorare la sicurezza dei sistemi informatici.

Computing Surveys, Vol. 8, No. 4, December 1976

Operating System Structures to Support Security and Reliable Software

THEODORE A. LINDEN

Institute for Computer Sciences and Technology, National Bureau of Standards, Washington, D.C. 20234

INTRODUCTION

For the year 1974, one source has identified 339 cases of computer-related crime.¹ The average loss in the 339 incidents was \$544,000. This average is not distorted by a few exceptional cases; the median loss was very close to the average. Most of the incidents involved simple fraud by an employee who had access to computerized financial records.

¹ This information is based on conversations with Robert Courtney. Courtney reports that details on these cases are in his possession, but that they cannot be made public. The work of Parker [PARK 75] based on public reports, supports a similar conclusion about the average loss in computer-related crime.

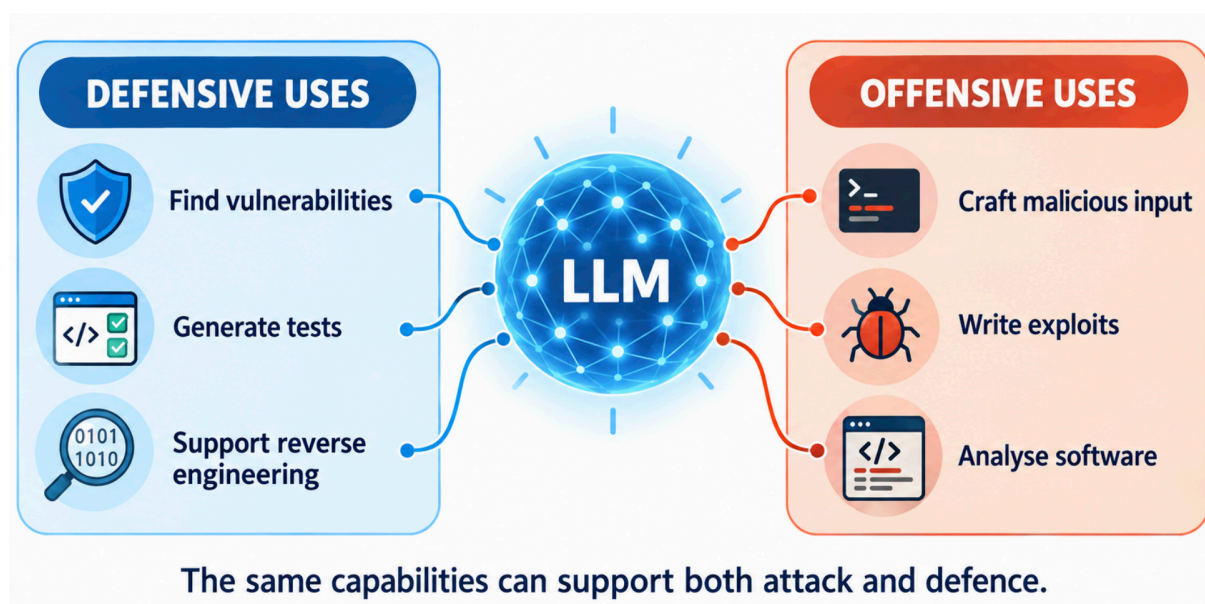
In 85 percent of the cases, management did not report the incident to the police—often because publicity about it would have been embarrassing.

The fraud is usually possible because of some oversight in an applications system. A simple oversight, for example, may allow a clerk to feed data to an accounts payable system in such a way that no one notices when checks are diverted to a dummy corporation.

If the amount of computer-related fraud is to be controlled, then it is necessary to automate the concepts of segregated duties, independent checking, and accountability for actions that are typical in manual ac-

L'avvento di Internet rompe l'isolamento fisico, all'inizio si pensava ci fosse un problema solo nelle comunicazioni ma ben presto si è capito che il problema era più ampio e riguardava anche i sistemi informatici stessi. **Luciano Floridi** definisce «l'infosfera» come l'ambiente informazionale che consiste in tutti gli oggetti informazionali, le loro relazioni, proprietà, interazioni processi e reazioni. Nell'era dell'AI e degli LLM, è importante interrogarsi su come la sicurezza informatica si evolverà e come le nuove tecnologie impatteranno nella nostra vita. Ora che l'AI è capace di scrivere codice in maniera automatica è importante capire come usarla per difendersi e attaccarsi.

- Gli LLM in difesa, possono trovare vulnerabilità, genera test e usarlo per fare reverse engineering
- Gli LLM in attacco, possono generare codice malevolo, trovare vulnerabilità e generare exploit.



Proteggere i sistemi software come l'autenticazione, access control, vulnerabilità, secure design è una prospettiva complementare all'analizzare e proteggere il software usando tecniche come reverse engineering, offuscazione, watermarking e anti-compromissione.

3 SOFTWARE SECURITY

La sicurezza non è solo un problema tecnico, ma anche un problema organizzativo e sociale. Le persone coinvolte nello sviluppo, inoltre la responsabilità della sicurezza del software non è solo degli sviluppatori, ma anche dei manager e dei tester. Anche i processi decisi al momento della fase di progettazione devono essere decisivi, decidendo polizze, procedure e incident response. Ovviamente la sicurezza si deve occupare di proteggere gli asset (tutto ciò di valore che deve essere protetto).

Per **temporalità** degli asset, si intende la proprietà degli asset di essere protetti per un certo periodo di tempo, ad esempio, i dati sensibili devono essere protetti per tutta la loro vita utile.

3.1 MINACCIA

Una *minaccia* è un impatto negativo indesiderato su un asset.



Figura 1: Minacce e vulnerabilità

Un esempio recente è successo nel settembre 2025, dove PyPi ha subito un attacco di supply chain, compromettendo 35 pacchetti e causando problemi a migliaia di utenti. L'attaccante ha ottenuto accesso a un account di un maintainer manomettendo il codice e abusando la fiducia degli utenti nel pacchetto.

Si può mettere manomettere il codice:

- Manomettendo il comoramento del codice
- Bypassando le licenze
- Piratando il software

Alcuni attacchi come:

- Attacchi di Data Breach (Information Disclosure): In questo attacco vengono rubati dati sensibili di aziende. Nel 2026, IBM ha fatto un report gli attacchi AI-driven sono aumentati del 56%.
- Denial of Service è un attacco che mira a rendere un servizio indisponibile per gli utenti legittimi. Questo può essere fatto sovraccaricando il sistema con richieste, sfruttando vulnerabilità o esaurendo le risorse del server.
- Elevation of Privileges, l'attaccante riesce ad estendere i suoi privilegi a cui ha accesso



CVE provides unique identifiers and standardized descriptions for publicly known vulnerabilities, while NVD is a vulnerability database maintained by NIST that enriches CVE records with technical details and severity metrics.



CERT/CC is a cybersecurity coordination center at Carnegie Mellon University that analyzes vulnerabilities, coordinates responsible disclosure, and publishes security advisories.



The Institute, established in 1989, is a leading organization that provides cybersecurity training, professional certifications, and security resources.

Figura 2: Monitoraggio delle istituzioni di sicurezza informatica

3.1.1 VALUTAZIONE DEL RISCHIO

Bisogna anche valutare il rischio di una minaccia e dare priorità ad essa e capire su quale fronte «spendere» per potersi difendere

- Si produce una lista di minacce e contromisure
- Si fa una valutazione del rischio e può essere costoso per grandi aziende
- Baseline protection prevede un livello minimo di sicurezza
- Monitoraggio continuo per rilevare nuove minacce e vulnerabilità
- Analisi di asset, minacce e vulnerabilità che ci permette di scegliere le giuste contromisure.

Le misure di protezione seguono questo workflow:

Protezione → Rilevare → Recuperare